

II Risk Management

Financial institution management should understand and evaluate risk across the institution, including the definitions and categories of risk. Risk is the potential that events, expected or unanticipated, may have an adverse effect on a financial institution's earnings, capital, or reputation. For regulatory purposes, risk is categorized as operational, liquidity, interest rate, credit, price, reputation, strategic, and compliance (legal). Although financial institution management should be aware of all potential risks as part of its overall risk management program, operational risk is the primary risk associated with IT.

II.A Operational Risk

Operational risk is the risk of failure or loss resulting from inadequate or failed processes, people, or systems. Operational risks from IT are present not only in back-office operations and transaction processing but also in areas such as customer service, systems development and support, internal controls and processes, and capacity planning. Operational risk may cross all lines of business and can be caused by internal or external events. Operational risk from IT primarily affects reputation, strategic, and compliance risks, although other risks may be affected.

Management should be aware of the implications of operational risk from IT, including the following:

- Strategic risk can stem from inaccurate information or analysis that causes management to make poor IT strategic decisions.
- Compliance risk can result from an institution's inability to meet the regulatory and legal requirements associated with its products and services. Compliance risk can also result from an institution's dependence on products and services to meet its operations and reporting requirements.
- Reputation risk can stem from errors, delays, omissions, unauthorized access to IT systems, or loss of confidential information that become public knowledge. Such occurrences may directly affect business partners and customers and may result in a loss of customers, customer withdrawal of funds, and loss of trust in the institution's products or services.

Management should have a comprehensive view of operations and business processes that are supported by technology. IT management should maintain an active role in institution strategic planning to align IT with established business goals and strategies. Additionally, management should ensure that effective IT controls exist throughout the institution, either through direct oversight or by holding lines of business accountable for IT-related controls. From a control standpoint, management should participate in the ITRM process to identify and measure risk from the use of IT, support decisions on how to mitigate the risks, implement the mitigation decisions, and monitor and report on the resulting outcomes.

III IT Risk Management

Action Summary

Financial institution management should develop an effective ITRM process that supports the broader risk management process. As part of the ITRM process, management should perform the following:

- Identify risks to information and technology assets within the financial institution or controlled by third-party providers.
- Measure the level of risk.
- Mitigate the risks to an acceptable residual risk level in conformance with the board's risk appetite.
- Monitor changing risk levels and report the results of the process to the board and senior management.

The ITRM process supports the enterprise-wide risk management framework through four activities: (1) risk identification, (2) risk measurement, (3) risk mitigation, and (4) risk monitoring and reporting. Risk identification generally documents inventories of systems and information necessary to financial institution operations and defines the potential threats to the institution's systems and operations. Risk measurement is a process of determining the likelihood of an adverse event or threat occurring and the potential impact of such an event on the institution. Risk mitigation includes the implementation of appropriate controls to reduce the potential for risk and bring the level of risk in line with the board's risk appetite. Monitoring and reporting provide the board and senior management with regular updates demonstrating the effectiveness of the risk management process.

Management should identify, measure, mitigate, monitor, and report IT risks that threaten the safety and soundness of an institution. An effective ITRM process is regularly updated and aligns IT and business objectives. This process should have a higher level of formality in more complex institutions.

The ITRM process is not complete without consideration of the overall IT environment. Management may need to consider risks associated with IT environments from two different perspectives:

- A centralized IT environment supports lines of business across shared infrastructure.
- A decentralized IT environment supports lines of business with separately managed infrastructure.

The following sections detail the processes involved in each of the ITRM activities.

III.A Risk Identification

Action Summary

Financial institution management should maintain a risk identification process that is coordinated and consistent throughout the institution. Risk identification includes ongoing data collection from existing activities and new initiatives.

All activities within a financial institution present a degree of risk. The nature of such risk, before applying controls and other mitigations, is called inherent risk. Senior management should ensure that IT risk identification efforts at the enterprise-wide level are coordinated and consistent throughout the institution. Management should maintain inventories of assets (e.g., hardware, software, and information), event classes (e.g., natural disaster, cyber, and insider abuse or compromise), threats (e.g., theft, malware, and social engineering), and existing controls as an important part of effective risk identification. Inventories should include systems and information hosted or maintained externally. Comprehensive IT risk identification should include identification of cybersecurity risks as well as details gathered during information security risk assessments required under guidelines implementing the GLBA.¹⁴ Participation in an information-sharing forum, such as FS-ISAC,¹⁵ should be a component of the risk identification process because sharing information may help the institution identify and evaluate relevant cybersecurity threats and vulnerabilities.¹⁶

Senior management should make risk management decisions based on a full understanding of identified risks. Small institutions with less complex systems may have a more simplified risk identification process. Regardless of the complexity, the process should be formal and adapt to changes in the IT environment. The effectiveness of the risk identification process is demonstrated by management's understanding and awareness of risk, the adequacy of formal risk assessments, and the effectiveness of the risk mitigation, including policies and internal controls.

III.A.1 Ongoing Data Collection

Understanding an institution's environment is the first step in any risk identification process. In identifying risks, management should collect and compile the following information regarding the institution's IT environment:

¹⁴ Refer to the "Information Security" booklet of the *IT Handbook* for more information on the GLBA and the "Interagency Guidelines Establishing Information Security Standards."

¹⁵ Refer to "[FFIEC Releases Cybersecurity Assessment Observations, Recommends Participation in Financial Services Information Sharing and Analysis Center](#)," November 3, 2014.

¹⁶ Ibid.

- **IT systems inventories:** These are critical to understanding the institution's IT infrastructure, as well as identifying the access and storage points for confidential customer and institution information.
- **IT strategic plan:** Such a plan can provide insight into the institution's planning process. Review and analysis of the strategic plan as part of the risk identification process may highlight developing risk exposures or other deficiencies that limit the institution's ability to implement strategic priorities.
- **Interconnectivity:**¹⁷ Management should comprehensively identify connections with third-party providers, including other financial institutions and financial institution intermediaries, because of the potential for significant operational risk through these interdependencies. In addition, management should identify all access points and connection types that pose risk, such as local or wide area network (LAN/WAN) connections to other networks or Internet service providers, cloud services, Wi-Fi, and cellular connections.
- **Information flow:** Management should document the flows of information throughout the institution, including flows of sensitive customer information. This documentation is critical to understanding what information assets the institution owns, where they are stored and transmitted, and who has access to them.
- **Business continuity and disaster recovery plans:** These plans prioritize the availability of various lines of business and often encompass restoration and provision of control and customer service and support. These plans can offer insight into the institution's critical operations and control environment.
- **Third-party management program:** Due diligence and monitoring present valuable information on the third-party provider's control environment. This information is necessary to identify the risks in an institution's IT environment.
- **Call center:** Issue tracking reports can often indicate potential performance or control issues if the problem reports are aggregated and analyzed for repetitive or common issues.
- **Self-assessments:** Assessments specifically on IT-related controls can provide early identification of policy noncompliance or weaknesses in controls.
- **IT audit findings:** These findings provide insight into the effectiveness of internal controls and staff and management's commitment to policy compliance.
- **Threat intelligence information:** By working with industry forums and groups, institutions can obtain information about emerging threats and the ways other organizations manage those threats.

In the process of collecting and compiling this information, management should include the potential cybersecurity risks associated with these areas of the financial institution's IT environment.

¹⁷ This term refers to the connections between networks that are owned and operated by different entities.

III.B Risk Measurement

Action Summary

Financial institution management should develop risk measurement processes that include the following elements:

- Measuring risk using qualitative, quantitative, or a hybrid of methods.
- Recognizing that risks do not exist in isolation.
- Prioritizing the risks based on the results of risk measurement.

Risk measurement typically is performed according to policies governing the enterprise-wide risk management process. Measurement is helpful in estimating the likelihood of an adverse event and its potential impact across the institution. Measurement across the financial institution is particularly important when an event impacts shared services and infrastructure or a shared customer base.

Measurements may be qualitative, quantitative, or a hybrid of both. Qualitative measures rely on experience, judgment, and intuition and are subject to potential flaws due to bias and other factors. Types of qualitative assessments include questionnaires or surveys to measure risk. Quantitative measures, on the other hand, are based on numerical values, such as dollar amounts or number of systems out of compliance. Quantitative measurement methods may include top-down and all-encompassing measures as well as measures that are limited to discrete activities and management choices. Hybrid measurements are frequently used and typically combine qualitative and quantitative measures to provide a more comprehensive analytical approach. A hybrid assessment could include a survey of staff to gain individual insight combined with numerical data inputs. Important considerations when evaluating hybrid measures include those presented above for both qualitative and quantitative measures.

Regardless of the method used, management should estimate the likelihood of occurrence and severity of the impact of the identified risk. When analyzing the potential impact, management should consider financial, reputation, or other impact to the institution. Organizational impacts are highly variable and not always easy to quantify. They include such considerations as lost revenue, data recovery and reconstruction expense, costs of litigation and potential judgments, loss of market share, and increases to premiums or denials of insurance coverage.

There are a variety of techniques, including the use of applications, to measure risk. Applications to provide measurement-related information may be developed in-house, acquired, or both. IT's role in development and acquisition should be consistent with the guidance in the *IT Handbook's* "Development and Acquisition" booklet.

The following are common types of risks that often have significant impact:

- **Security breaches:** Including internal and external breaches, weak program code used to perpetrate fraud, and computer viruses.
- **System failures:** Including telecommunication failures, LAN and WAN failures, hardware and software failures, interconnectivity failures, and backup system failures.
- **External events:** Including weather-related events, earthquakes, pandemics, terrorism, cyber attacks, cut utility lines (e.g., telecommunication, water, and power), or widespread power outages.
- **Insider events:** Including intentional or unintentional acts by staff, such as carelessness, social engineering that results in inappropriate access or the installation of malware, and improper changes to transactions, systems, or databases.
- **Development and acquisition issues:** Including strategic platform or supplier risk, inappropriate definition of business requirements, incompatibility with existing systems, inadequate project management, programming errors (internal or external), change management issues, failure to integrate and/or migrate systems or applications successfully, or obsolescence of software.
- **Capacity planning issues:** Including inadequate capacity planning or inaccurate forecasts of growth.
- **Third-party provider issues:** Including deficiencies in the oversight of third-party providers in areas such as reporting, breach notification, business continuity and resilience testing, and subcontracting (fourth-party) risk management.

The institution should recognize that no risk exists in isolation; there are interdependencies among risks. This reinforces the need for an integrated approach for risk management. To ensure accurate risk measurement, management should ensure that risk assessments are updated regularly, and as changes occur, to address new technologies, products, services, and connections before deployment.

The IT department can have a specialized and unique role in the measurement and prioritization of IT-related threats, based on its expertise in the development, application, and use of IT. Institution management should use that expertise, as well as the expertise provided by others (e.g., auditors, third-party providers, and other third parties), in the risk measurement process. Once management identifies and measures the institution's IT risk, it should rank the risks and prioritize its response.

III.C Risk Mitigation

Action Summary

Financial institution management should implement effective control and risk transfer practices as part of its overall IT risk mitigation strategy. These practices should include the following:

- Establishing, implementing, and enforcing IT policies, standards, and procedures.
- Documenting policies for hiring and training personnel.
- Implementing internal controls for information security risks.
- Establishing and implementing effective cybersecurity controls.
- Developing and testing formal business continuity plans.
- Establishing and implementing a well-managed and controlled software development and acquisition function.
- Controlling, managing, and monitoring an IT operations function.
- Reviewing insurance for IT operations, including cyber insurance.
- Developing an effective third-party management program.

Risk mitigation is the process of reducing risks through the introduction of specific controls. Risk mitigation decisions are implemented through the use of controls or risk transfer. Risk transfer can be accomplished through mechanisms such as insurance. After implementing controls or transferring the risk, management should determine the level of residual risk, or the risk that cannot be fully mitigated or avoided. Both controls and risk transfer should be considered when evaluating whether a residual risk is within the financial institution's risk appetite. Risk appetite is the amount of risk a financial institution is prepared to accept when trying to achieve its objectives.

Controls are implemented in financial institution activities and may be performed either manually by staff or through automated systems. Controls can be classified by timing (preventive, detective, corrective) or nature (administrative, technical, physical). Refer to the *IT Handbook's* "Information Security" booklet for more information. The IT department generally implements controls within the institution for assets that are under the IT department's control. Non-IT-related controls implemented elsewhere in the financial institution should be coordinated with the IT department to ensure their adequacy.

Controls should be evaluated for effectiveness against identified threats or vulnerabilities. Evaluation typically is accomplished by tools that supplement and complement assurance and audit activities. Two examples of tools used are control self-assessments and scenario analysis. Control self-assessments, used internally to assess the effectiveness of ITRM processes and related controls, typically are performed by departments or lines of business periodically testing and validating their controls. Scenario analysis is a process of analyzing possible future events by considering alternative outcomes. It can be a valuable tool for gaining an overall

understanding of the exposure to existing, expected, and plausible (including potentially severe) events, as well as the robustness of—or gaps in—controls or other risk mitigation.

Additionally, a control self-assessment should encompass external requirements, such as laws, regulations, and widely accepted control standards and practices.¹⁸ Failure to comply with external requirements, whether in law, regulation, or contract, can result in compliance risk as well as strategic, reputation, or other risks. Conformance with widely accepted control standards and practices can demonstrate due care in the operation of IT and potentially reduce operational risk.

Conformance with external requirements alone is not sufficient to ensure that the overall ITRM process is adequate. The ITRM process encompasses risk posed by the operation of the financial institution in its specific internal and external environment. Accordingly, the ITRM process should consider whether the IT control structure, when combined with controls outside the IT systems, adequately mitigates risk associated with the use of IT.

III.C.1 Policies, Standards, and Procedures

In general, a policy is a governing principle that provides the basis for standards and is adopted by the board. The policy is an overall statement of the institution's philosophy or intent. Standards are mandatory criteria that ensure conformity with policy, government regulations, and acceptable levels of control. Procedures are typically documents that describe, in detail, the behavior or processes used to adhere to the criteria mandated by standards. Clearly written and frequently communicated policies can establish clear assignments of duties, help staff coordinate and perform their tasks effectively and consistently, and aid in training staff. Senior management should ensure that policies, standards, and procedures are current, well documented, and integrated with the institution's information security strategy.

Institution management should create, document, maintain, and adhere to policies, standards, and procedures to manage and control the institution's IT risk. The level of detail depends on the complexity of the IT environment but should enable management to monitor the identified risk posture. Review of adherence to documented policies, standards, and procedures may be performed internally, by a risk or compliance function in the institution, or through independent audit. This review often helps to identify problems early so they can be corrected before they become serious.

III.C.2 Personnel

The institution should mitigate risks posed by IT staff by performing appropriate background checks and screening of new staff. The controls in this section also are relevant for third-party provider staff, consultants, and temporary personnel who support the IT function. Typically, the minimum verification considerations should include the following:

¹⁸ Examples of widely accepted industry standards include National Institute of Standards and Technology (NIST) publications, the Control Objectives for Information and Related Technology (COBIT) framework, and the Information Technology Infrastructure Library (ITIL).

- Background checks, including confirmations of prior experience, academic credentials, professional qualifications, or criminal records.¹⁹
- Confirmation of identity from government-issued identification.
- Character references.

The institution should use job descriptions, employment agreements (usually for higher-level or higher-sensitivity positions), training, and awareness programs to promote understanding and increase individual accountability. The job descriptions should detail duties and responsibilities and be routinely updated by managers responsible for the positions with assistance from HR. Management should document and confirm access privileges for each staff member based on his or her job description. Additionally, management should establish a timely process to review, update, and remove access privileges associated with any party when appropriate. The lack of such a process may result in unauthorized or inappropriate activity. Failure to remove access privileges when appropriate, particularly for those individuals with high levels of privilege, represents significant risk.

The institution should protect the confidentiality of information about its customers and organization by having new hires sign agreements covering confidentiality, nondisclosure, and authorized use as a condition of their employment. Employment agreements set both the expectations and limits associated with the staff member's functions. Management should obtain signed confidentiality and nondisclosure agreements before granting new staff members, contractors, and temporary staff access to IT systems. In addition, management should require periodic acknowledgement of acceptable use policies for the network, software applications, Internet, e-mail, confidential data, and social media. Information security awareness and training programs help support information security and other management policies.

III.C.3 Information Security

Financial institutions are critically dependent on their information and technology assets—hardware, software, and data. Management should protect information and technology assets to ensure operational continuity, financial viability, and the trust of customers. The unauthorized loss, destruction, or disclosure of confidential information can adversely affect a financial institution's reputation, earnings, and capital.

The board of directors is responsible for overseeing the development, implementation, management, and maintenance of the institution's information security program. This oversight includes assigning specific responsibility and accountability for the program's implementation and reviewing reports from management. The board should provide management with guidance, review the effectiveness of management's actions, and annually approval written information

¹⁹ Section 19 of the Federal Deposit Insurance Act prohibits, without the prior written consent of the Federal Deposit Insurance Corporation (FDIC), a person convicted of any criminal offense involving dishonesty or breach of trust or money laundering (covered offenses), or who has agreed to enter into a pretrial diversion or similar program in connection with a prosecution for such offense, from becoming or continuing as an institution-affiliated party, owning or controlling, directly or indirectly an insured depository institution (insured institution), or otherwise participating, directly or indirectly, in the conduct of the affairs of the insured institution, See 12 U.S.C. 1829.

security policies and a written information security program. Key elements that should be addressed in the information security program include the following:

- Central oversight and coordination.
- Areas of responsibility.
- Risk measurement.
- Implementation of controls.
- Monitoring and testing of effectiveness of controls.
- Reporting.
- Acceptable residual risk.

The information security program should be coordinated across the institution. To ensure the effectiveness of the information security program throughout the institution, management should have a process to hold staff accountable for complying with the information security program. Institution management should perform the following:

- Develop and implement processes to identify and protect against security events and incidents.
- Develop, implement, and periodically test incident response procedures, which should address escalation, remediation, and reporting of events and incidents.
- Develop and implement a threat intelligence and collaboration process to identify and respond to information on threats and vulnerabilities.
- Consider information security risks when developing, implementing, or updating products.
- Ensure that products are developed or updated in accordance with established information security policies and procedures.
- Perform penetration tests before launching or making significant changes to critical systems, including Internet- and client-facing applications. Management should review all findings and develop processes to ensure the timely remediation of issues identified by the tests.
- Conduct initial due diligence and ongoing monitoring to fully understand the types of connections and mitigating controls in place between the financial institution and its third-party providers. In conjunction with this, management should require by contract that the third-party providers notify the institution of the use of any subcontractors or changes to subcontractor relationships.²⁰
- Implement a governance process to establish, monitor, maintain, and test controls to mitigate interconnectivity risk.
- Develop a policy for escalating and reporting security incidents to the board, government agencies, law enforcement, and the institution's primary federal and state regulator based on thresholds defined by the financial institution and applicable legal requirements. Relevant thresholds could include significant financial impact, significant operational downtime, operational or system breach, or loss of critical infrastructure.

Refer to the *IT Handbook's* "Information Security" booklet for more information.

²⁰ Refer to the *FFIEC IT Handbook's* "[Outsourcing Technology Services](#)" booklet.